PENETRATION TESTING REPORT

Phase 1: Footprinting & Reconnaissance | Phase 2: Network Scanning

CONFIDENTIAL

Pentester Name	**Raphael Osindi**	**Program / Batch**	Batch 084 – Networkwalks
Date of Testing	10 November 2026	**Modules Completed**	W2-PM1 (Kali Tools) & W2-PM5 (Zenmap & OSINT)
Client / Target	Networkwalks (Target Domain: networkwalks.com) & Local LAN	**Scope & Permission**	Authorized (LOA Granted / Educational Scope)
Professional Links	LinkedIn Profile GitHub Repository		

> **1. Liability Disclaimer:** All technical assessment activities documented herein were executed under strict authorization on systems explicitly covered by written consent or self-owned lab environments. This document serves educational and research purposes under the Networkwalks Cybersecurity Internship framework. Unsanctioned use of these methodologies outside defined scope violates applicable cybersecurity regulations and criminal codes.

2. EXECUTIVE SUMMARY & INTRODUCTION

This technical report delivers a comprehensive analysis of security assessments performed during Week 2 of the Networkwalks Cybersecurity Internship (Batch 084). The engagement covered active and passive reconnaissance (W2-PM1) alongside target infrastructure fingerprinting and active scanning (W2-PM5).

The objective was to evaluate the target domain (`networkwalks.com`) and internal lab subnets to identify publicly reachable assets, service exposures, host configurations, and firewall protections. Using industry-standard security tools (Nslookup, Curl, Wafw00f, DNSRecon, Maltego, and Nmap/Zenmap), data was collected to establish an attack surface assessment without executing destructive exploits.

3. ASSESSMENT METHODOLOGY & TOOLING

TOOL	CATEGORY	ASSESSMENT OBJECTIVE
Nslookup	DNS Querying Utility	Perform A-record resolution to locate public hosting IP addresses.
Curl	HTTP Header Inspection	Retrieve raw HTTP response headers, identify web servers, and reveal API endpoints.
Wafw00f	WAF Fingerprinting	Identify Web Application Firewall presence, vendor, and interception logic.
DNSRecon	DNS Enumeration	Harvest SOA, NS, MX, TXT, and SRV records to discover internal/external infrastructure details.
Maltego Graph	OSINT & Entity Mapping	Map structural relationships between target domains, administrative emails, and subdomains.
Zenmap / Nmap	Port & Service Scanner	Execute intense service/OS discovery scans (`-T4 -A -v`) against target hosts.

4. ACTIVITY EXECUTION & TECHNICAL FINDINGS

4.1 Phase 1: Passive & Active Reconnaissance

Reconnaissance commenced with basic host resolution using **Nslookup**, confirming that `networkwalks.com` resolves to public IP address `192.232.216.135` via Cloudflare public DNS (1.1.1.1).

Subsequent HTTP header inspection via **Curl** (`curl -I https://networkwalks.com`) revealed key technical metadata: execution over Apache web server, active WordPress deployment, and explicit disclosure of the WordPress REST API endpoint (`/wp-json/`). Cookies such as `__wpdm_client` confirmed active use of WordPress Download Manager.

Target WAF analysis using **Wafw00f** identified that the web application is protected by a **ModSecurity (SpiderLabs)** Web Application Firewall, establishing that initial HTTP inspects are mediated by rule-based defenses.

Full DNS enumeration using **DNSRecon** yielded 8 critical records including SOA/NS directives pointing to HostGator infrastructure (`ns6135.hostgator.com` / `ns6136.hostgator.com`), SPF authorization records (`v=spf1 +a +mx +ip4:50.87.144.87`), and multiple cPanel autodiscover SRV records. Notably, DNSRecon flagged active recursion enabled on name servers (`192.232.216.131` and `50.87.144.87`).

OSINT mapping via **Maltego Desktop** linked target entity `networkwalks.com` directly to administrative contact channels including `info@networkwalks.com` and registrar abuse contacts (`abuse@godaddy.com`).

4.2 Phase 2: Host Scanning & Service Fingerprinting

An intense Nmap scan (`nmap -T4 -A -v 192.232.216.135`) executed in **Zenmap** provided deeper insight into host configuration:

- **Open Port 2222/tcp:** Running `OpenSSH 9.9 (protocol 2.0)` on a non-standard port for remote administration.
- **Open Port 3306/tcp:** Running `MySQL 5.7.44-48` with SSL/TLS enabled (RapidSSL / DigiCert certificate bound to `*.hostgator.com`). Direct accessibility to database ports increases exposure to brute-force or authentication bypass attempts if unprotected by network filters.
- **OS & Host Detection:** Host kernel identified as Linux 3.4 – 5.15 with an active uptime of ~34.5 days (Host system node: `gator3068.hostgator.com`).

5. RISK ANALYSIS & VULNERABILITY MATRIX

#	FINDING / EXPOSURE	TECHNICAL OBSERVATION	IMPACT	RISK LEVEL
1	Database Port Exposed	MySQL 5.7.44 (Port 3306) open to external network scan.	Exposes database service directly to remote brute-force and direct authentication risks.	• Medium

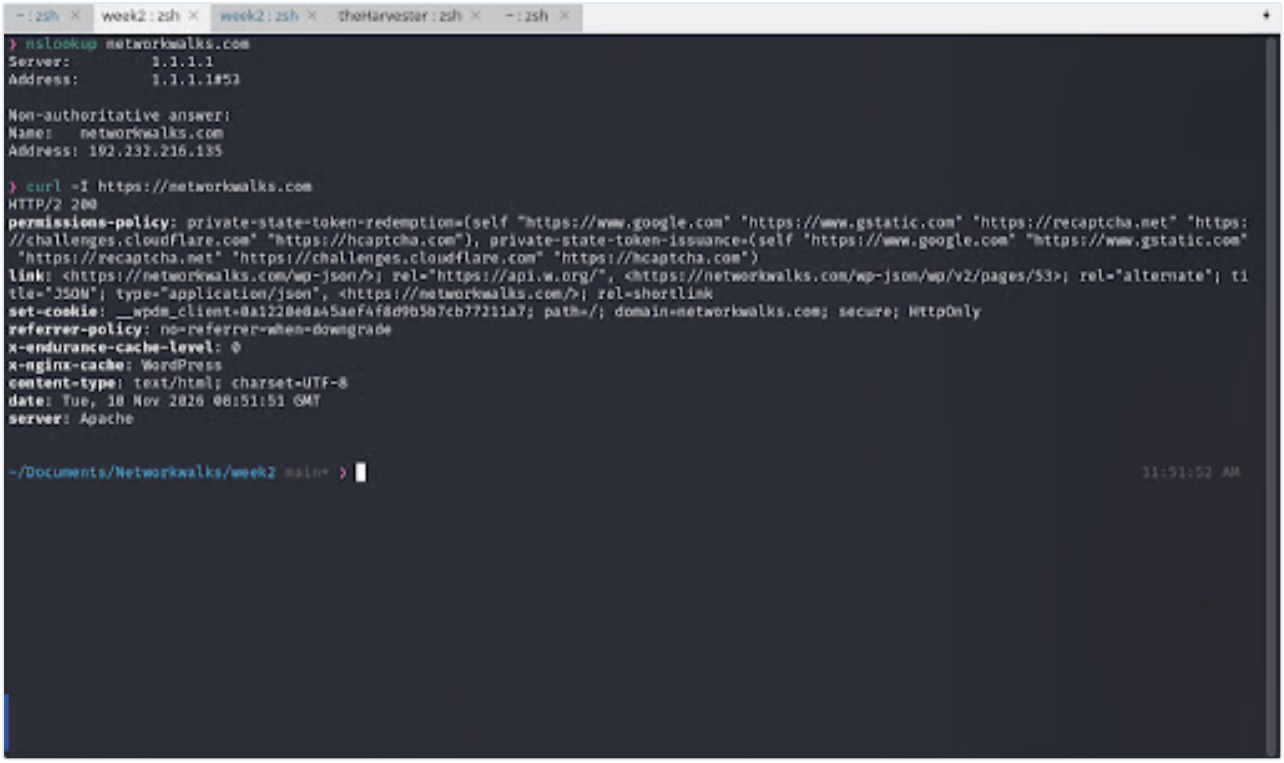
#	FINDING / EXPOSURE	TECHNICAL OBSERVATION	IMPACT	RISK LEVEL
2	DNS Recursion Enabled	DNSRecon reported recursion enabled on primary NS hosts.	Can be leveraged by third parties for DNS amplification Distributed Denial of Service (DDoS).	• Medium
3	Technology Fingerprint Exposure	HTTP headers and REST API (`/wp-json/`) exposed via Curl.	Provides precise CMS target details allowing attackers to tailor version-specific exploits.	• Low
4	Non-Standard SSH Port	OpenSSH 9.9 reachable over custom TCP port 2222.	Obfuscates service location but remains discoverable during basic port sweeps.	• Informational
5	WAF Detection Confirmed	ModSecurity (SpiderLabs) identified via Wafw00f.	Active defensive controls verified; limits basic automated attack vectors.	• Informational

6. STRATEGIC REMEDIATION RECOMMENDATIONS

Restrict Database Access: Bind MySQL (Port 3306) to internal loopback (127.0.0.1) or restrict access strictly via firewall IP whitelisting to prevent unauthorized direct connections. **Disable Unnecessary DNS Recursion:** Reconfigure authoritative DNS servers (`ns6135` / `ns6136`) to disable open recursion for external queries. **Harden HTTP Response Headers:** Suppress server banners (Apache version, CMS header tags) and restrict REST API endpoint visibility where unnecessary. **Enforce SSH Key Authentication:** Secure OpenSSH on Port 2222 by enforcing public-key authentication and disabling root password logins. **Maintain WAF Rule Sets:** Regularly update ModSecurity signature sets to mitigate emerging web application vulnerabilities.

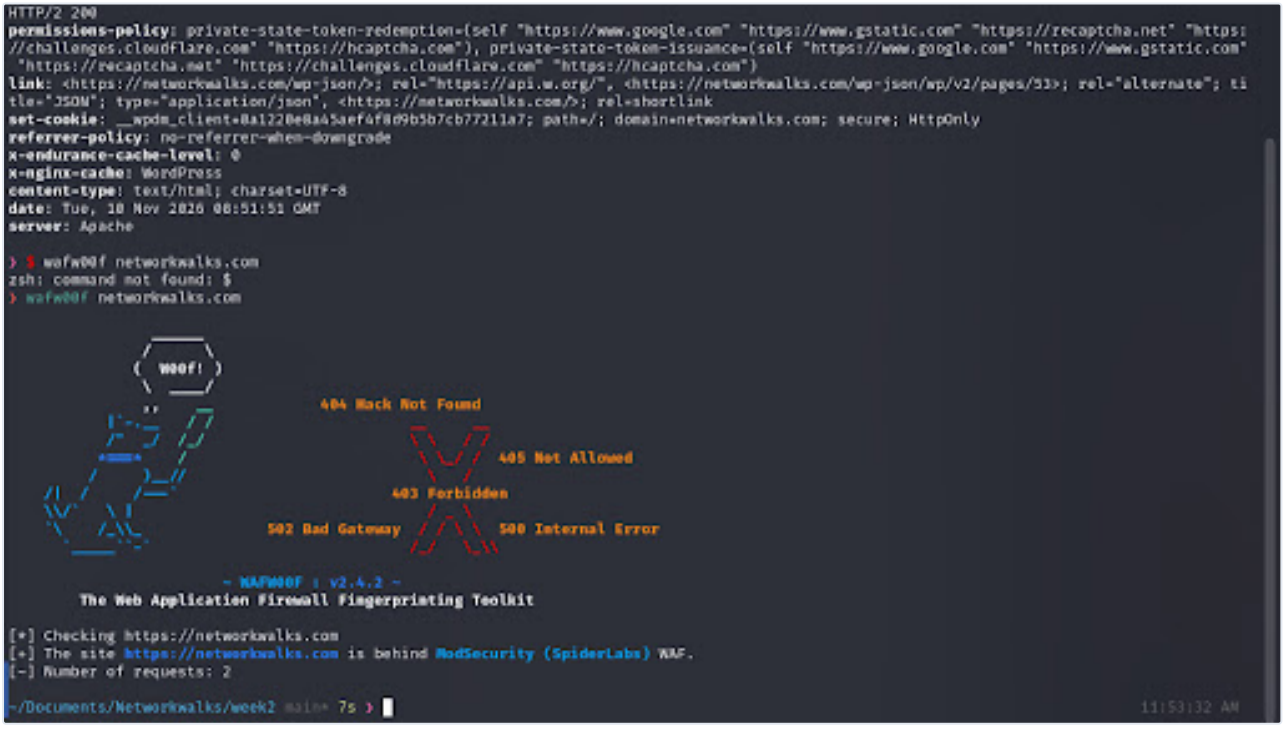
7. TECHNICAL EVIDENCES & VERIFICATION ARTIFACTS

Evidence Artifact 1: Nslookup & Curl HTTP Header Output **Target: networkwalks.com**



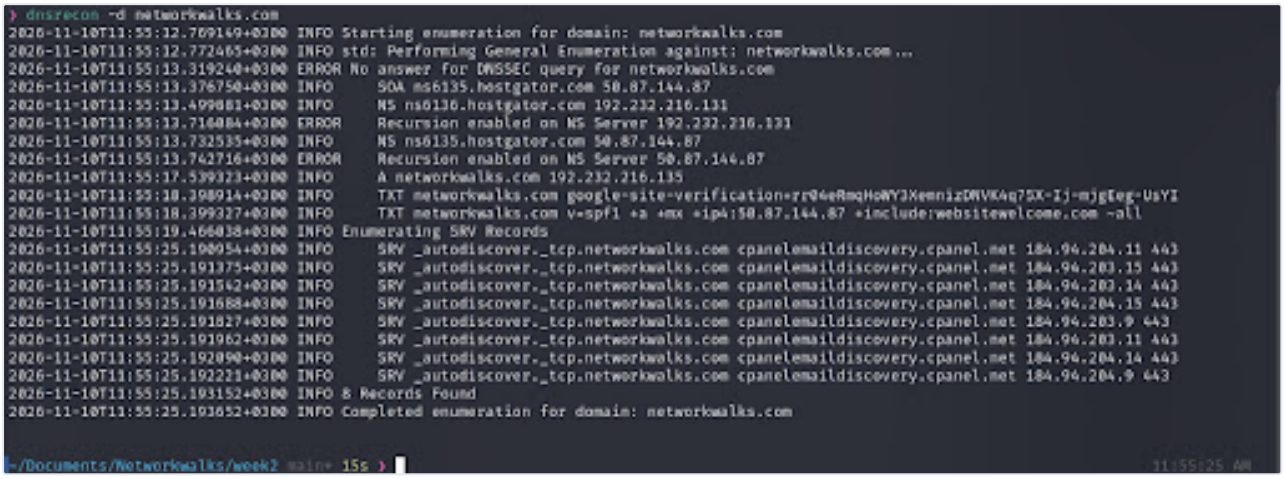

```
❯ nslookup networkwalks.com -> Address: 192.232.216.135
❯ curl -I https://networkwalks.com -> HTTP/2 200 OK | Server: Apache | x-nginx-cache: WordPress
```

Evidence Artifact 2: Wafw00f WAF Detection Scan **Tool: Wafw00f v2.4.2**



```
[+] The site https://networkwalks.com is behind ModSecurity (SpiderLabs) WAF.
```

Evidence Artifact 3: DNSRecon Enumeration Execution **Domain: networkwalks.com**



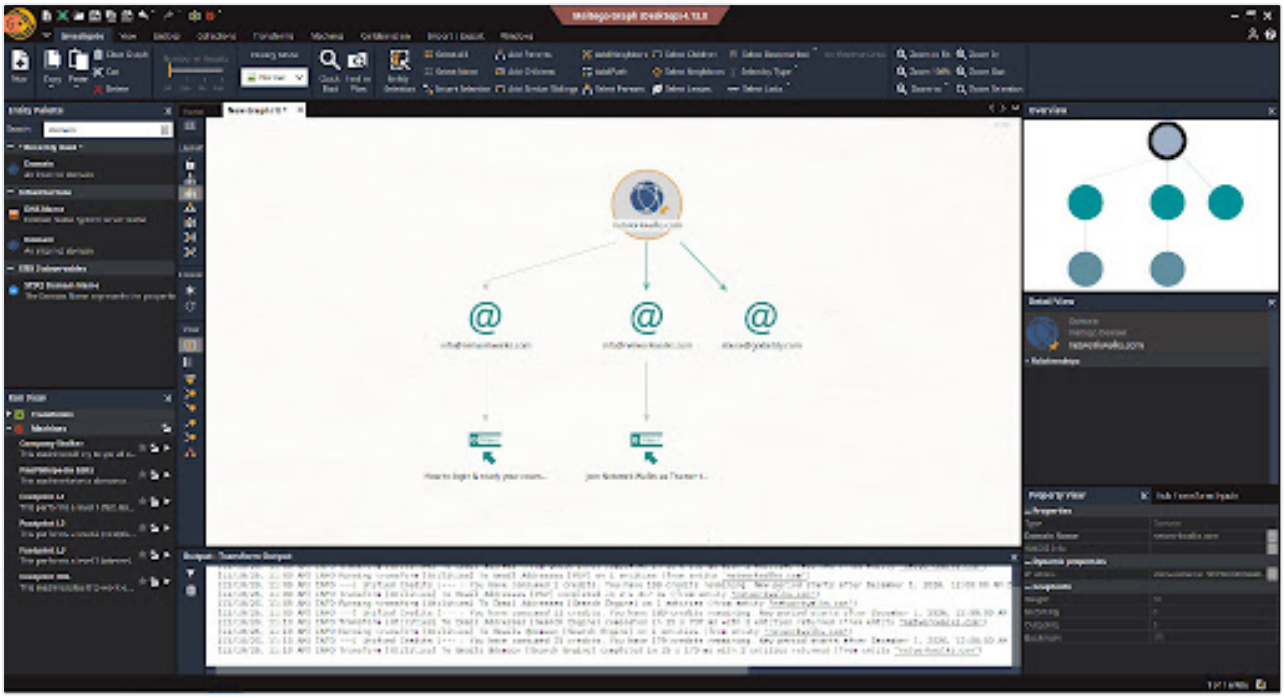

```
INFO A networkwalks.com 192.232.216.135
ERROR Recursion enabled on NS Server 192.232.216.131
INFO TXT v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all
```

Evidence Artifact 4: Zenmap Intense Scan Output (Nmap) **Command: nmap -T4 -A -v 192.232.216.135**



```
2222/tcp open  ssh   OpenSSH 9.9 (protocol 2.0)
3306/tcp open  mysql MySQL 5.7.44-48
Aggressive OS guesses: Linux 3.4 - 5.15
```

Evidence Artifact 5: Maltego OSINT Graph Topology **Target Node: networkwalks.com**



```
Transform Results: Mapped entity relationships across domain nodes, email handles, and
hosting servers.
```

8. CONCLUSION

The footprinting and scanning phases conducted by **Raphael Osindi** under **Batch 084** successfully mapped the external network perimeter and target configuration of `networkwalks.com`. The technical results demonstrate how open-source intelligence combined with active network probing provides essential clarity on potential entry points and security postures. Implementing the provided recommendations will significantly enhance target defense prior to future testing phases.